ENTREGABLE TÉCNICO · FASE 2

Plan de despliegue masivo de 20 agentes y política de retención

Implementación proyectada de Wazuh para PagoClaro Fintech S.A.S. · SOC Nivel 1

Responsable: Nelson Enrique Sierra Perez | Trabajo académico individual

Fecha de emisión: 21 de octubre de 2026 | Versión 1.0

Estado de control: Plan documentado. La política de retención está definida, pero su aplicación en el indexer y el archivo externo sigue pendiente de verificación.

1. Objetivo, alcance y línea base

Planificar la extensión del monitoreo del SOC desde el laboratorio piloto hasta los 20 equipos empresariales del caso C05, manteniendo trazabilidad de los eventos, cobertura por sistema operativo, control del almacenamiento y conservación segura de evidencias.

El piloto ya muestra dos agentes operativos en Wazuh (Windows-Agent y Ubuntu-Agent), con pruebas previas de FIM, SCA, vulnerabilidades, reglas locales, active response y el tablero “SOC N1 – Resumen”. Estos endpoints representan escenarios funcionales del caso: no prueban que los 20 equipos del inventario empresarial estén desplegados.

2. Inventario objetivo y segmentación

Grupo / identificador propuesto	Cantidad	Segmento	Cobertura prevista
Windows 11: W11-OPS-01 a 08	8	VLAN 10	Operaciones y soporte; autenticación, integridad y eventos de seguridad.
Windows 11: W11-LAP-01 a 03	3	VLAN 10	Gerencia y cumplimiento; autenticación, cambios y cumplimiento de configuración.
macOS: MAC-DEV-01 a 05	5	VLAN 10	Desarrollo; eventos del sistema, cambios críticos y postura de seguridad.
Ubuntu: UBU-APP, UBU-DB, UBU-BKP	3	VLAN 20	Aplicación, réplica de BD y respaldos; privilegios, servicios y archivos críticos.
Ubuntu: UBU-BAS	1	VLAN 30	Bastión; sesiones administrativas, escalamiento de privilegios y accesos.
TOTAL	20	3 segmentos	Inventario empresarial objetivo; no equivale a 20 agentes ya instalados.

Los identificadores anteriores son nomenclatura propuesta, no nombres de hosts verificados. El Wazuh todo en uno y la consola de Kaspersky son infraestructura adicional y no forman parte de estos 20 equipos.

3. Arquitectura y requisitos previos

Topología empresarial proyectada: agentes en VLAN 10 (usuarios), VLAN 20 (servidores) y VLAN 30 (gestión); comunicaciones de agentes hacia Wazuh Manager, restringidas por origen y destino. La práctica disponible utiliza una red Host-only de VirtualBox; las VLAN y los servicios IaaS son de diseño, no infraestructura física desplegada.

- Validar Ubuntu Server LTS, estado de wazuh-manager, wazuh-indexer y wazuh-dashboard, fecha/NTP, espacio en disco y respaldo de configuración antes de nuevas altas.
- Comprobar conectividad autorizada a 1514/TCP para eventos y 1515/TCP para registro de agentes; restringir el acceso web administrativo y proteger certificados y credenciales.
- Homologar compatibilidad de Wazuh Agent para Windows 11, macOS y Ubuntu y evitar un agente más reciente que el Manager sin validación de soporte.
- Dimensionar crecimiento hasta 26 agentes (20 + margen del 30 %); monitorear CPU, RAM, disco e ingesta, y ampliar capacidad si el volumen real lo exige.

4. Secuencia de despliegue y criterios de aprobación

Etapa	Lote	Actividad controlada	Puerta de salida
0 · Preparación	20 registros	Conciliar inventario, responsables, IP y sistema operativo; respaldos, permisos y ventana autorizada.	Matriz inventario–agente aprobada; servicios sanos y conectividad comprobada.
1 · Piloto	2 agentes de laboratorio	Conservar la validación Windows/Linux existente como referencia funcional.	Eventos en tablero, FIM/SCA y estado “Active” documentados.
2 · Críticos	4 Ubuntu empresariales	Bastión, aplicación, réplica BD y respaldos; activar controles ajustados por rol.	Cuatro agentes activos; cambios y privilegios detectables sin exceso de ruido.
3 · Usuarios	11 Windows 11	Desplegar primero lote reducido y ampliar al resto tras revisión de estabilidad.	Once altas registradas; eventos y políticas verificables por equipo.
4 · Desarrollo	5 macOS	Instalar agente compatible; habilitar permisos necesarios y validar FIM/SCA donde aplique.	Cinco altas activas; pruebas por macOS registradas.
5 · Cierre	20 empresariales	Auditoría de inventario, cobertura, excepciones y almacenamiento.	20/20 agentes empresariales con evidencia; pendientes documentados.

La secuencia es una propuesta futura para un entorno empresarial autorizado. En esta entrega solo se ha ejecutado el piloto representativo de dos agentes.

5. Procedimiento operativo común

- Desde Wazuh Dashboard, generar la instrucción de instalación por plataforma y versión verificada; no insertar credenciales ni tokens en capturas o repositorio.
- Instalar el agente con permisos administrativos autorizados, configurar el Manager y habilitar inicio automático del servicio.
- Asignar grupos de configuración por rol (usuarios Windows, desarrollo macOS, servidores Ubuntu, bastión), evitando aplicar FIM indiscriminado.
- Verificar el registro del agente, su última conexión y la recepción de un evento de prueba benigno; registrar versión, hostname, IP y responsable.

- Comprobar FIM de rutas definidas, SCA según compatibilidad, vulnerabilidades y reglas de autenticación; validar detecciones PagoClaro C05 cuando exista la fuente.
- Cerrar cada lote con revisión de falsos positivos, carga de recursos, riesgo de respuesta activa y evidencia de reversión.

6. Seguridad y reversión

Aplicar mínimo privilegio, segmentación, autenticación administrativa restringida y comunicación cifrada entre componentes cuando corresponda. Los registros de VPN y cuenta privilegiada simulados deben etiquetarse como sintéticos. Antes de activar respuestas automáticas, usar lista blanca de administradores y pruebas en el laboratorio.

Si una nueva versión provoca fallos o degrada el equipo, detener nuevas altas, deshabilitar temporalmente el componente problemático en el lote afectado, restaurar su configuración respaldada y verificar el funcionamiento de los servicios; documentar incidencia y autorización. No realizar un borrado masivo de agentes ni de índices como medida inicial.

7. Política de retención acordada

La guía del docente (Fase 1, p. 42) propone 90 días consultables y 12 meses archivados; la arquitectura de PagoClaro C05 adopta esos plazos. En la Fase 2 se exige demostrar la política aplicada. La permanencia de datos indexados y la conservación de un archivo protegido son controles separados.

Clase de información	Plazo / destino	Mecanismo de control
Alertas indexadas de Wazuh	90 días / Wazuh Indexer	Política de ciclo de vida sobre wazuh-alerts-*; validación por antigüedad, espacio y estado del índice.
Eventos originales y evidencias seleccionadas	12 meses / repositorio externo protegido	Exportación y respaldo verificables; cifrado, acceso restringido, manifiesto SHA-256 y restauración probada.
Configuración de SIEM / GLPI	Copia diaria; plazo por formalizar	Respaldo diario, versiones y ensayo documentado de recuperación; no confundir con archivo de eventos.
Datos con sensibilidad elevada	Según restricciones aplicables	Minimización, seudonimización, acceso por rol y eliminación controlada al vencimiento aprobado.

8. Aplicación técnica en Wazuh: procedimiento verificable

Estado real: la retención de 90 días está definida documentalmente; no contamos aún con exportación de la política ISM activa, un repositorio de archivos de 12 meses ni pruebas de restauración. Por tanto, la implementación queda pendiente y debe evidenciarse antes de marcarla como “aplicada”.

- Antes de cambiar políticas, conservar copia de seguridad recuperable del indexer y de las configuraciones; inventariar índices vigentes y comprobar salud, asignación y espacio.
- En Wazuh Dashboard → Indexer management → Dev Tools ejecutar consultas de solo lectura: GET _cluster/health; GET _cat/indices/wazuh-alerts-*?v; GET _cat/allocation?v&s=node; GET _opendistro/_ism/explain/wazuh-alerts-*.
- En Indexer management → Index Management preparar una política ISM con permanencia en estado activo y transición a eliminación al superar 90 días de edad del índice. Asociarla únicamente a la familia de alertas pertinente y verificar aplicación a índices existentes y futuros.

- Antes de habilitar la acción destructiva, disponer de repositorio externo protegido: exportación/snapshot y, cuando aplique, archivos originales; generar hashes, controlar permisos y probar restauración de una muestra.
- Registrar política, patrón, fecha, condiciones, ejecución y resultado. Verificar que los índices todavía dentro de la ventana de 90 días siguen consultables y que la eliminación de índices antiguos no precede al archivo validado.
- Revisar periódicamente salud del cluster, tamaño de índices, utilización del disco y funcionamiento del ciclo de vida. Recalcular capacidad al incorporar 20 agentes y fuentes de red/cloud.

Precisión técnica: la edad de un índice no es necesariamente idéntica a la edad de cada documento. La política ISM no produce por sí sola una copia de archivo de 12 meses; la eliminación debe quedar condicionada a que exista respaldo restaurable. Nunca usar una regla de borrado genérica para índices wazuh-* sin inventario previo.

9. Evidencias, responsables y criterios de aceptación

Entregable / control	Prueba objetiva	Estado al emitir este documento
Inventario y fases de despliegue	20 equipos desglosados por SO, rol y segmento; orden de alta y puntos de control.	Documentado; despliegue completo pendiente.
Piloto de monitoreo	Capturas de servicios y dos agentes activos; alertas FIM/SCA, CVE y tablero SOC N1.	Evidencia de laboratorio disponible.
ISM 90 días	Captura del editor de política + salida explain y listado de índices.	Pendiente de aplicación y captura.
Archivo protegido 12 meses	Ubicación externa, permisos, cifrado, manifiesto y prueba de restauración.	Pendiente de implementación y prueba.
Capacidad y revisión	Uso de disco/índices y acta de evaluación para 20–26 agentes.	Pendiente de medición durante el despliegue.

Responsabilidad propuesta: administrador del SIEM ejecuta y valida políticas; responsable SOC N1 revisa alertas y cobertura; responsable de seguridad autoriza cambios de conservación; encargado de respaldos custodia archivo y evidencia. En el ejercicio individual estas funciones son roles metodológicos, no cargos empresariales comprobados.

10. Archivos de respaldo de la Fase 2

Ubicar en E:\SOC_C05\Fase_2\ los archivos de configuración ya exportados (agent.conf, local_rules.xml y local_decoder.xml), las capturas de pruebas y las siguientes evidencias de retención cuando existan: F02_25_Plan_Despliegue_Retencion.docx, F02_26_Politica_ISM_90d.png, F02_27_Verificacion_ISM.txt, F02_28_Archivo_12meses.png y F02_29_Prueba_Restauracion.txt. Los nombres son una convención sugerida.

11. Referencias documentales

- Parcial_SOC_N1_Etica_Hacking.pdf, caso C05 (p. 18), Fase 1 (p. 42) y Fase 2 (p. 48): inventario, retención recomendada y evidencias exigidas.
- Fase1_Arquitectura_SOC_C05.pdf, pp. 1, 4, 6–7: inventario de 20 activos, segmentación, margen del 30 % y conservación de evidencias.
- Wazuh Documentation (consulta técnica): “Cluster management”, “Wazuh indexer indices” y “Wazuh indexer API – Index State Management”. https://documentation.wazuh.com/current/

Nota de alcance: este documento formaliza el plan y la política seleccionada. No reemplaza la captura de configuración real ni la prueba de retención en Wazuh.